

1. You are flying on a plane to install an electronic healthcare record system for a client. The person next to you is Paul Akers from FastCap, a company that provides carpentry material and teaches Lean process improvement for free. Paul (CEO) learns you know a lot about managing information systems and asks you the following, “Every week I hear about companies being attacked by ransomware. Please give me a layperson definition of what ransomware is and at least two examples of healthcare organizations attacked by ransomware? What were the consequences to their operations?”

Ransomware is a type of malicious software designed to block access to computer systems or data until a ransom is paid. Cybercriminals use it to encrypt files or lock users out of computer systems then demand payment to restore access. While ransomware can sometimes be removed, the process is often complex and varies depending on the specific variant involved.

In 2021, the healthcare sector experienced two major ransomware incidents that underscored the growing vulnerability of critical infrastructure. The first and most recent incident involved Change Healthcare, a leading healthcare technology company responsible for managing billing and payment processes. This attack had a widespread and long-lasting impact, particularly on UnitedHealthcare, arguably the largest health insurance provider in the United States. The breach disrupted claims processing, payment workflows for providers and patients, and critical real-time medical operations. The effects of the attack reverberated for years across the healthcare industry.

The second major incident affected Scripps Health, a prominent healthcare provider in Southern California. Network systems went offline to contain the infection and caused a temporary loss to EHR (electronic health records) access. This led to significant delays in patient care and disrupted scheduled appointments and services.

Both incidents highlighted the increasing risks ransomware poses to the healthcare industry. Key vulnerabilities were exposed in areas such as billing, payment systems, data security, and supply chains. Beyond operational disruptions, the financial consequences were also substantial. For instance, the Change Healthcare incident was estimated to have cost UnitedHealthcare approximately \$22 million dollars.

2. Paul continues to ask, “How do companies become infected with ransomware? How does the ransomware get inside the company? Tell me more than just ‘hackers.’ What are at least two methods or vulnerabilities that allow hackers to infect a company?”

The two most common ways companies are attacked and infected with ransomware are through phishing emails and unpatched VPNs or Remote Desktop Protocol (RDP) vulnerabilities.

Phishing emails are malicious emails sent by attackers posing as trusted sources. These emails often contain infected links or attachments designed to trick users into clicking or opening them, which then installs the ransomware. This method remains the most common and effective due to the high volume of email communication in the workplace and the general lack of awareness or training on how to recognize phishing attempts.

The second most common attack vector involves unpatched VPNs, firewalls, or RDP services. RDP is a protocol that enables users to remotely access and control another computer over a network. Cybercriminals exploit vulnerabilities in outdated RDP versions or use stolen login credentials obtained from data breaches. Once access is gained, attackers can disable security tools and manually deploy ransomware across the network.

3. Paul’s follow-up question is “I want to protect my company Fastcap from ransomware. What five things can companies can do to prevent ransomware or at least to make the company a harder target against the attack?”

1. Be skeptical of unexpected requests for sensitive information
2. Train employees regularly on security awareness - not to click on suspicious links or download unknown attachments and carefully review sender's information
3. Use multi-factor authentication - implement stronger security tools
4. Routinely back up data, and keep software and system up to date
5. Use antivirus/antimalware tools

4. Paul thank you for your time and asks one final question, “If a company becomes infected, what is the best way to recover from the attack without paying the blackmail?”

If a company becomes infected, below is a list of actions to take to recover. Additionally, getting law enforcement involved is advised. Paying the ransom should always be the last resort.

1. Isolate infected system(s)
2. Disable network connection(s) such as shared drives and cloud sync to prevent further spread
3. Identify the scope of impact and quarantine
4. Verify backup integrity
5. Restore from backups if possible

5. List at least five, specific sources that you used to learn more about ransomware (website, youtube videos, white papers, Ted talks, live interviews, etc.). Just list the URLs, no need to format APA.

1. National Cyber Security Centre <https://www.ncsc.gov.uk>
2. US Chamber of Commerce
<https://www.uschamber.com/co/run/technology/ransomware-attacks-business-protection>
3. FBI (Federal Bureau of Investigation) website - <https://www.fbi.gov>
4. CISA (Cybersecurity and Infrastructure Security Agency) <https://www.cisa.gov>
5. Hearing - Andrew Witty YouTube/CNBC
<https://www.cnn.com/2024/05/01/unitedhealth-ceo-says-company-paid-hackers-22-million-ransom.html>
6. ChatGPT
7. Google

6. AI Transparency: Briefly disclose how you used AI and in what capacity. AI use is encouraged to help you learn and assist. Share the prompts if you used AI.

- Definitions to see all varieties summarized in one place
- Confirm my definitions and insights
- Suggested examples I may have missed from other sources
- Learn more about RDP
- Basic content check (e.g. grammar, spellcheck, etc.)